kshield report – DORA Chapter II – Regulation (EU) 2022/2554 and RTS (EU) 2024/1774

This report supports evidence for the requirements it cites. It is not an audit and does not state compliance with any regulation.

Scan

Tool	kshield 0.0.0–deterministic
Profile	dora v1
Profile sha256	a4c816e97c89586b6edfb2bce79c2e18d351b41c350879466df41fb6785c3a90
Mode	manifest
Inputs	test/corpus/baseline/toxic/input.yaml
Input files	test/corpus/baseline/toxic/input.yaml sha256 9d98c3b878d9151d2aabb98890ef826e434f714fa2c1b6da042a315838acc469
Namespace	ai–inference
Started at	1970–01–01T00:00:00Z
Objects	5
AI workloads	5

Summary

17 FAIL **4 WARN** **7 PASS** **0 INFO** **5 N/A**

Checks

FAIL DORA–CH2–001 KS–WL–001 Container may run as root (no runAsNonRoot: true, or UID 0) – severity fail, fix: workload patch (kshield remediate)

FAIL DORA–CH2–002 KS–WL–002 privileged: true or allowPrivilegeEscalation not false – severity fail, fix: workload patch (kshield remediate)

FAIL DORA–CH2–003 KS–WL–003 Capabilities not dropped (drop: [ALL] missing) – severity fail, fix: workload patch (kshield remediate)

PASS DORA–CH2–004 KS–WL–004 hostIPC, hostPID or hostNetwork true – severity fail, fix: workload patch (kshield remediate)

FAIL DORA–CH2–005 KS–WL–005 /dev/shm from hostPath (or hostPath /dev) – severity fail, fix: workload patch (kshield remediate)

PASS DORA–CH2–006 KS–WL–006 Memory emptyDir for shm without sizeLimit – severity warn, fix: workload patch (kshield remediate)

PASS DORA–CH2–007 KS–WL–007 shareProcessNamespace: true on AI workload – severity fail, fix: workload patch (kshield remediate)

WARN DORA–CH2–008 KS–WL–008 Root filesystem writable – severity warn, fix: workload patch (kshield remediate)

FAIL DORA–CH2–009 KS–WL–009 No seccompProfile: RuntimeDefault – severity fail, fix: workload patch (kshield remediate)

FAIL DORA–CH2–010 KS–WL–010 Service account token auto–mounted – severity fail, fix: workload patch (kshield remediate)

PASS DORA–CH2–011 KS–WL–011 Secret values in plain env (HF_TOKEN, API keys) – severity fail, fix: manual (kshield checks explain KS–WL–011)

WARN DORA–CH2–012 KS–WL–012 Image not pinned by digest – severity warn, fix: manual (kshield checks explain KS–WL–012)

WARN DORA–CH2–013 KS–WL–013 No memory limit on AI workload – severity warn, fix: manual (kshield checks explain KS–WL–013)

FAIL DORA–CH2–014 KS–WL–014 GPU access via hostPath /dev/nvidia* or privileged, not device plugin – severity fail, fix: manual (kshield checks explain KS–WL–014)

FAIL DORA–CH2–015 KS–AI–001 vLLM API without auth (––api–key / VLLM_API_KEY unset) – severity fail, fix: manual (kshield checks explain KS–AI–001)

FAIL DORA–CH2–016 KS–AI–002 vLLM ––trust–remote–code set – severity fail, fix: workload patch (kshield remediate)

WARN DORA–CH2–017 KS–AI–003 Model load may use pickle – severity fail, fix: workload patch (kshield remediate)

FAIL DORA-CH2-018 KS-AI-004 Inference API exposed outside cluster (Service LoadBalancer/NodePort, Ingress) without auth – severity fail, fix: manual (kshield checks explain KS-AI-004)

FAIL DORA-CH2-019 KS-AI-005 Ray GCS 6379, client 10001 or dashboard 8265 exposed beyond ClusterIP – severity fail, fix: workload patch (kshield remediate)

FAIL DORA-CH2-020 KS-AI-006 Ray TLS off (RAY_USE_TLS not 1) – severity fail, fix: manual (kshield checks explain KS-AI-006)

PASS DORA-CH2-021 KS-AI-007 Ollama 11434 exposed without an auth proxy – severity fail, fix: manual (kshield checks explain KS-AI-007)

FAIL DORA-CH2-022 KS-AI-008 Qdrant without API key or TLS – severity fail, fix: manual (kshield checks explain KS-AI-008)

PASS DORA-CH2-023 KS-AI-009 Milvus authorization disabled – severity fail, fix: manual (kshield checks explain KS-AI-009)

FAIL DORA-CH2-024 KS-NET-001 AI namespace has no default-deny egress (no CNP/NetworkPolicy in input or cluster) – severity fail, fix: guardrail policy (kshield remediate)

PASS DORA-CH2-025 KS-NET-002 Egress allow-list too broad (world, 0.0.0.0/0) – severity fail, fix: guardrail policy (kshield remediate)

N/A DORA-CH2-026 KS-NET-003 Pod-to-pod encryption off (Cilium WireGuard/IPsec) – severity fail, fix: manual (kshield checks explain KS-NET-003)

FAIL DORA-CH2-027 KS-RT-001 No runtime shell-exec guard on AI namespace (Tetragon) – severity fail, fix: guardrail policy (kshield remediate)

FAIL DORA-CH2-028 KS-RT-002 No runtime egress-connect guard on AI namespace (Tetragon) – severity fail, fix: guardrail policy (kshield remediate)

FAIL DORA-CH2-029 KS-RT-003 No admission guard for root, host namespaces, shm hostPath, pickle load (Kyverno) – severity fail, fix: guardrail policy (kshield remediate)

N/A DORA-CH2-030 KS-PRE-001 Tetragon missing or unhealthy – severity fail, fix: manual (kshield checks explain KS-PRE-001)

N/A DORA-CH2-031 KS-PRE-002 CNI is not Cilium (L7/FQDN egress not possible) – severity fail, fix: manual (kshield checks explain KS-PRE-002)

N/A DORA-CH2-032 KS-PRE-003 Kyverno missing or unhealthy – severity fail, fix: manual (kshield checks explain KS-PRE-003)

N/A DORA-CH2-033 KS-PRE-004 Node kernel lacks BPF LSM (--node-probe) – severity warn, fix: manual (kshield checks explain KS-PRE-004)

Findings

FAIL DORA-CH2-001 KS-WL-001 Container may run as root (no runAsNonRoot: true, or UID 0)

severity fail | fix: workload patch (kshield remediate)

Supports evidence for

DORA Art. 9(4)(c)

DORA, CELEX 32022R2554, https://eur-lex.europa.eu/eli/reg/2022/2554/oj

> implement policies that limit the physical or logical access to information assets and ICT assets to what is required for legitimate and approved functions and activities only, and establish to that end a set of policies, procedures and controls that address access rights and ensure a sound administration thereof;

Findings (5)

DORA-CH2-001 Deployment/ai-inference/qdrant container may run as root: runAsNonRoot is not true and runAsUser is not set

verdict	FAIL
container	qdrant
path	/spec/template/spec/containers/0/securityContext/runAsNonRoot
source	test/corpus/baseline/toxic/input.yaml:57

DORA–CH2–001 Deployment/ai–inference/vllm container may run as root: runAsNonRoot is not true and runAsUser is not set

verdict	**FAIL**
container	vllm
path	/spec/template/spec/containers/0/securityContext/runAsNonRoot
source	test/corpus/baseline/toxic/input.yaml:1

DORA–CH2–001 RayCluster/ai–inference/rc container may run as root: runAsNonRoot is not true and runAsUser is not set

verdict	**FAIL**
group	cpu
container	ray–worker
path	/spec/workerGroupSpecs/0/template/spec/containers/0/securityContext/runAsNonRoot
source	test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–001 RayCluster/ai–inference/rc container may run as root: runAsNonRoot is not true and runAsUser is not set

verdict	**FAIL**
group	gpu
container	ray–worker
path	/spec/workerGroupSpecs/1/template/spec/containers/0/securityContext/runAsNonRoot
source	test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–001 RayCluster/ai–inference/rc container may run as root: runAsNonRoot is not true and runAsUser is not set

verdict	**FAIL**
group	head
container	ray–head
path	/spec/headGroupSpec/template/spec/containers/0/securityContext/runAsNonRoot
source	test/corpus/baseline/toxic/input.yaml:107

FAIL DORA–CH2–002 KS–WL–002 privileged: true or allowPrivilegeEscalation not false

severity fail | fix: workload patch (kshield remediate)

Supports evidence for

DORA Art. 9(4)(c)

DORA, CELEX 32022R2554, https://eur–lex.europa.eu/eli/reg/2022/2554/oj

> implement policies that limit the physical or logical access to information assets and ICT assets to what is required for legitimate and approved functions and activities only, and establish to that end a set of policies, procedures and controls that address access rights and ensure a sound administration thereof;

Findings (5)

DORA–CH2–002 Deployment/ai–inference/qdrant allowPrivilegeEscalation is not set to false

verdict	**FAIL**
container	qdrant
path	/spec/template/spec/containers/0/securityContext/allowPrivilegeEscalation
source	test/corpus/baseline/toxic/input.yaml:57

DORA–CH2–002 Deployment/ai–inference/vllm allowPrivilegeEscalation is not set to false

verdict	**FAIL**
container	vllm
path	/spec/template/spec/containers/0/securityContext/allowPrivilegeEscalation
source	test/corpus/baseline/toxic/input.yaml:1

DORA–CH2–002 RayCluster/ai–inference/rc allowPrivilegeEscalation is not set to false

verdict	**FAIL**
group	cpu
container	ray–worker
path	/spec/workerGroupSpecs/0/template/spec/containers/0/securityContext/allowPrivilegeEscalation
source	test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–002 RayCluster/ai–inference/rc allowPrivilegeEscalation is not set to false
verdict FAIL
group gpu
container ray–worker
path /spec/workerGroupSpecs/1/template/spec/containers/0/securityContext/allowPrivilegeEscalation
source test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–002 RayCluster/ai–inference/rc allowPrivilegeEscalation is not set to false
verdict FAIL
group head
container ray–head
path /spec/headGroupSpec/template/spec/containers/0/securityContext/allowPrivilegeEscalation
source test/corpus/baseline/toxic/input.yaml:107

FAIL DORA–CH2–003 KS–WL–003 Capabilities not dropped (drop: [ALL] missing)

severity fail | fix: workload patch (kshield remediate)

Supports evidence for

DORA Art. 9(4)(c)

DORA, CELEX 32022R2554, https://eur–lex.europa.eu/eli/reg/2022/2554/oj

> implement policies that limit the physical or logical access to information assets and ICT assets to what is required for legitimate and approved functions and activities only, and establish to that end a set of policies, procedures and controls that address access rights and ensure a sound administration thereof;

Findings (5)

DORA–CH2–003 Deployment/ai–inference/qdrant capabilities.drop does not contain ALL
verdict FAIL
container qdrant
path /spec/template/spec/containers/0/securityContext/capabilities
source test/corpus/baseline/toxic/input.yaml:57

DORA–CH2–003 Deployment/ai–inference/vllm capabilities.drop does not contain ALL
verdict FAIL
container vllm
path /spec/template/spec/containers/0/securityContext/capabilities
source test/corpus/baseline/toxic/input.yaml:1

DORA–CH2–003 RayCluster/ai–inference/rc capabilities.drop does not contain ALL
verdict FAIL
group cpu
container ray–worker
path /spec/workerGroupSpecs/0/template/spec/containers/0/securityContext/capabilities
source test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–003 RayCluster/ai–inference/rc capabilities.drop does not contain ALL
verdict FAIL
group gpu
container ray–worker
path /spec/workerGroupSpecs/1/template/spec/containers/0/securityContext/capabilities
source test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–003 RayCluster/ai–inference/rc capabilities.drop does not contain ALL
verdict FAIL
group head
container ray–head
path /spec/headGroupSpec/template/spec/containers/0/securityContext/capabilities
source test/corpus/baseline/toxic/input.yaml:107

FAIL DORA-CH2-005 KS-WL-005 /dev/shm from hostPath (or hostPath /dev)

severity fail | fix: workload patch (kshield remediate)

Supports evidence for

DORA Art. 9(3)(c)

DORA, CELEX 32022R2554, https://eur-lex.europa.eu/eli/reg/2022/2554/oj

> prevent the lack of availability, the impairment of the authenticity and integrity, the breaches of confidentiality and the loss of data;

Findings (1)

DORA-CH2-005 Deployment/ai-inference/vllm volume "shm" mounts hostPath /dev/shm

verdict	FAIL
path	/spec/template/spec/volumes/1
source	test/corpus/baseline/toxic/input.yaml:1

WARN DORA-CH2-008 KS-WL-008 Root filesystem writable

severity warn | fix: workload patch (kshield remediate)

Supports evidence for

DORA Art. 9(3)(b)

DORA, CELEX 32022R2554, https://eur-lex.europa.eu/eli/reg/2022/2554/oj

> minimise the risk of corruption or loss of data, unauthorised access and technical flaws that may hinder business activity;

DORA Art. 9(3)(c)

DORA, CELEX 32022R2554, https://eur-lex.europa.eu/eli/reg/2022/2554/oj

> prevent the lack of availability, the impairment of the authenticity and integrity, the breaches of confidentiality and the loss of data;

Findings (5)

DORA-CH2-008 Deployment/ai-inference/qdrant readOnlyRootFilesystem is not set to true

verdict	WARN
container	qdrant
path	/spec/template/spec/containers/0/securityContext/readOnlyRootFilesystem
source	test/corpus/baseline/toxic/input.yaml:57

DORA-CH2-008 Deployment/ai-inference/vllm readOnlyRootFilesystem is not set to true

verdict	WARN
container	vllm
path	/spec/template/spec/containers/0/securityContext/readOnlyRootFilesystem
source	test/corpus/baseline/toxic/input.yaml:1

DORA-CH2-008 RayCluster/ai-inference/rc readOnlyRootFilesystem is not set to true

verdict	WARN
group	cpu
container	ray-worker
path	/spec/workerGroupSpecs/0/template/spec/containers/0/securityContext/readOnlyRootFilesystem
source	test/corpus/baseline/toxic/input.yaml:107

DORA-CH2-008 RayCluster/ai-inference/rc readOnlyRootFilesystem is not set to true

verdict	WARN
group	gpu
container	ray-worker
path	/spec/workerGroupSpecs/1/template/spec/containers/0/securityContext/readOnlyRootFilesystem
source	test/corpus/baseline/toxic/input.yaml:107

DORA-CH2-008 RayCluster/ai-inference/rc readOnlyRootFilesystem is not set to true

verdict	WARN
group	head
container	ray-head
path	/spec/headGroupSpec/template/spec/containers/0/securityContext/readOnlyRootFilesystem
source	test/corpus/baseline/toxic/input.yaml:107

FAIL DORA-CH2-009 KS-WL-009 No seccompProfile: RuntimeDefault

severity fail | fix: workload patch (kshield remediate)

Supports evidence for

DORA Art. 9(4)(c)

DORA, CELEX 32022R2554, https://eur-lex.europa.eu/eli/reg/2022/2554/oj

implement policies that limit the physical or logical access to information assets and ICT assets to what is required for legitimate and approved functions and activities only, and establish to that end a set of policies, procedures and controls that address access rights and ensure a sound administration thereof;

RTS 2024/1774 Art. 11(2)(b)

RTS 2024/1774, CELEX 32024R1774, https://eur-lex.europa.eu/eli/reg_del/2024/1774/oj

the identification of a secure configuration baseline for ICT assets that minimise exposure of those ICT assets to cyber threats and measures to verify regularly that those baselines are effectively deployed;

Findings (5)

DORA-CH2-009 Deployment/ai-inference/qdrant seccompProfile is not set: the container runs without a seccomp profile

verdict	FAIL
container	qdrant
path	/spec/template/spec/containers/0/securityContext/seccompProfile
source	test/corpus/baseline/toxic/input.yaml:57

DORA-CH2-009 Deployment/ai-inference/vllm seccompProfile is not set: the container runs without a seccomp profile

verdict	FAIL
container	vllm
path	/spec/template/spec/containers/0/securityContext/seccompProfile
source	test/corpus/baseline/toxic/input.yaml:1

DORA-CH2-009 RayCluster/ai-inference/rc seccompProfile is not set: the container runs without a seccomp profile

verdict	FAIL
group	cpu
container	ray-worker
path	/spec/workerGroupSpecs/0/template/spec/containers/0/securityContext/seccompProfile
source	test/corpus/baseline/toxic/input.yaml:107

DORA-CH2-009 RayCluster/ai-inference/rc seccompProfile is not set: the container runs without a seccomp profile

verdict	FAIL
group	gpu
container	ray-worker
path	/spec/workerGroupSpecs/1/template/spec/containers/0/securityContext/seccompProfile
source	test/corpus/baseline/toxic/input.yaml:107

DORA-CH2-009 RayCluster/ai-inference/rc seccompProfile is not set: the container runs without a seccomp profile

verdict	FAIL
group	head
container	ray-head
path	/spec/headGroupSpec/template/spec/containers/0/securityContext/seccompProfile
source	test/corpus/baseline/toxic/input.yaml:107

FAIL DORA-CH2-010 KS-WL-010 Service account token auto-mounted

severity fail | fix: workload patch (kshield remediate)

Supports evidence for

DORA Art. 9(4)(c)

DORA, CELEX 32022R2554, https://eur-lex.europa.eu/eli/reg/2022/2554/oj

implement policies that limit the physical or logical access to information assets and ICT assets to what is required for legitimate and approved functions and activities only, and establish to that end a set of policies, procedures and controls that address access rights and ensure a sound administration thereof;

Findings (5)

DORA–CH2–010 Deployment/ai–inference/qdrant automountServiceAccountToken is not false on the pod, and ServiceAccount "default" in namespace "ai–inference" does not set it to false

verdict	**FAIL**
path	/spec/template/spec/automountServiceAccountToken
source	test/corpus/baseline/toxic/input.yaml:57

DORA–CH2–010 Deployment/ai–inference/vllm automountServiceAccountToken is not false on the pod, and ServiceAccount "default" in namespace "ai–inference" does not set it to false

verdict	**FAIL**
path	/spec/template/spec/automountServiceAccountToken
source	test/corpus/baseline/toxic/input.yaml:1

DORA–CH2–010 RayCluster/ai–inference/rc automountServiceAccountToken is not false on the pod, and ServiceAccount "default" in namespace "ai–inference" does not set it to false

verdict	**FAIL**
group	cpu
path	/spec/workerGroupSpecs/0/template/spec/automountServiceAccountToken
source	test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–010 RayCluster/ai–inference/rc automountServiceAccountToken is not false on the pod, and ServiceAccount "default" in namespace "ai–inference" does not set it to false

verdict	**FAIL**
group	gpu
path	/spec/workerGroupSpecs/1/template/spec/automountServiceAccountToken
source	test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–010 RayCluster/ai–inference/rc automountServiceAccountToken is not false on the pod, and ServiceAccount "default" in namespace "ai–inference" does not set it to false

verdict	**FAIL**
group	head
path	/spec/headGroupSpec/template/spec/automountServiceAccountToken
source	test/corpus/baseline/toxic/input.yaml:107

WARN DORA–CH2–012 KS–WL–012 Image not pinned by digest

severity warn | fix: manual (kshield checks explain KS–WL–012)

Supports evidence for

DORA Art. 9(4)(e)

DORA, CELEX 32022R2554, https://eur–lex.europa.eu/eli/reg/2022/2554/oj

> implement documented policies, procedures and controls for ICT change management, including changes to software, hardware, firmware components, systems or security parameters, that are based on a risk assessment approach and are an integral part of the financial entity's overall change management process, in order to ensure that all changes to ICT systems are recorded, tested, assessed, approved, implemented and verified in a controlled manner;

RTS 2024/1774 Art. 16(1)(c)

RTS 2024/1774, CELEX 32024R1774, https://eur–lex.europa.eu/eli/reg_del/2024/1774/oj

> specify measures to mitigate the risk of unintentional alteration or intentional manipulation of the ICT systems during the development, maintenance, and deployment of those ICT systems in the production environment.

Findings (5)

DORA–CH2–012 Deployment/ai–inference/qdrant image "qdrant/qdrant:v1.19.2" has no @sha256: digest

verdict	**WARN**
container	qdrant
path	/spec/template/spec/containers/0/image
source	test/corpus/baseline/toxic/input.yaml:57

DORA–CH2–012 Deployment/ai–inference/vllm image "vllm/vllm–openai:v0.31.0" has no @sha256: digest

verdict	**WARN**
container	vllm
path	/spec/template/spec/containers/0/image
source	test/corpus/baseline/toxic/input.yaml:1

DORA–CH2–012 RayCluster/ai–inference/rc image "rayproject/ray:2.50.0" has no @sha256: digest

verdict	WARN
group	cpu
container	ray–worker
path	/spec/workerGroupSpecs/0/template/spec/containers/0/image
source	test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–012 RayCluster/ai–inference/rc image "rayproject/ray:2.50.0–gpu" has no @sha256: digest

verdict	WARN
group	gpu
container	ray–worker
path	/spec/workerGroupSpecs/1/template/spec/containers/0/image
source	test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–012 RayCluster/ai–inference/rc image "rayproject/ray:2.50.0" has no @sha256: digest

verdict	WARN
group	head
container	ray–head
path	/spec/headGroupSpec/template/spec/containers/0/image
source	test/corpus/baseline/toxic/input.yaml:107

WARN DORA–CH2–013 KS–WL–013 No memory limit on AI workload

severity warn | fix: manual (kshield checks explain KS–WL–013)

Supports evidence for

DORA Art. 9(2)

DORA, CELEX 32022R2554, https://eur–lex.europa.eu/eli/reg/2022/2554/oj

> Financial entities shall design, procure and implement ICT security policies, procedures, protocols and tools that aim to ensure the resilience, continuity and availability of ICT systems, in particular for those supporting critical or important functions, and to maintain high standards of availability, authenticity, integrity and confidentiality of data, whether at rest, in use or in transit.

Findings (5)

DORA–CH2–013 Deployment/ai–inference/qdrant resources.limits.memory is not set

verdict	WARN
container	qdrant
path	/spec/template/spec/containers/0/resources/limits/memory
source	test/corpus/baseline/toxic/input.yaml:57

DORA–CH2–013 Deployment/ai–inference/vllm resources.limits.memory is not set

verdict	WARN
container	vllm
path	/spec/template/spec/containers/0/resources/limits/memory
source	test/corpus/baseline/toxic/input.yaml:1

DORA–CH2–013 RayCluster/ai–inference/rc resources.limits.memory is not set

verdict	WARN
group	cpu
container	ray–worker
path	/spec/workerGroupSpecs/0/template/spec/containers/0/resources/limits/memory
source	test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–013 RayCluster/ai–inference/rc resources.limits.memory is not set

verdict	WARN
group	gpu
container	ray–worker
path	/spec/workerGroupSpecs/1/template/spec/containers/0/resources/limits/memory
source	test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–013 RayCluster/ai–inference/rc resources.limits.memory is not set

verdict	WARN
group	head
container	ray–head
path	/spec/headGroupSpec/template/spec/containers/0/resources/limits/memory
source	test/corpus/baseline/toxic/input.yaml:107

FAIL DORA-CH2-014 KS-WL-014 GPU access via hostPath /dev/nvidia* or privileged, not device plugin

severity fail | fix: manual (kshield checks explain KS-WL-014)

Supports evidence for

DORA Art. 9(4)(c)

DORA, CELEX 32022R2554, https://eur-lex.europa.eu/eli/reg/2022/2554/oj

implement policies that limit the physical or logical access to information assets and ICT assets to what is required for legitimate and approved functions and activities only, and establish to that end a set of policies, procedures and controls that address access rights and ensure a sound administration thereof;

Findings (1)

DORA-CH2-014 RayCluster/ai-inference/rc volume "nvidia0" mounts hostPath /dev/nvidia0 (request GPUs through the device plugin with nvidia.com/gpu limits)

verdict	FAIL
group	gpu
path	/spec/workerGroupSpecs/1/template/spec/volumes/0
source	test/corpus/baseline/toxic/input.yaml:107

FAIL DORA-CH2-015 KS-AI-001 vLLM API without auth (--api-key / VLLM_API_KEY unset)

severity fail | fix: manual (kshield checks explain KS-AI-001)

Supports evidence for

DORA Art. 9(4)(c)

DORA, CELEX 32022R2554, https://eur-lex.europa.eu/eli/reg/2022/2554/oj

implement policies that limit the physical or logical access to information assets and ICT assets to what is required for legitimate and approved functions and activities only, and establish to that end a set of policies, procedures and controls that address access rights and ensure a sound administration thereof;

DORA Art. 9(4)(d)

DORA, CELEX 32022R2554, https://eur-lex.europa.eu/eli/reg/2022/2554/oj

implement policies and protocols for strong authentication mechanisms, based on relevant standards and dedicated control systems, and protection measures of cryptographic keys whereby data is encrypted based on results of approved data classification and ICT risk assessment processes;

Findings (1)

DORA-CH2-015 Deployment/ai-inference/vllm vLLM serves without authentication: neither --api-key nor the VLLM_API_KEY env var is set

verdict	FAIL
container	vllm
path	/spec/template/spec/containers/0/args
source	test/corpus/baseline/toxic/input.yaml:1

FAIL DORA-CH2-016 KS-AI-002 vLLM --trust-remote-code set

severity fail | fix: workload patch (kshield remediate)

Supports evidence for

DORA Art. 9(3)(b)

DORA, CELEX 32022R2554, https://eur-lex.europa.eu/eli/reg/2022/2554/oj

minimise the risk of corruption or loss of data, unauthorised access and technical flaws that may hinder business activity;

DORA Art. 9(3)(c)

DORA, CELEX 32022R2554, https://eur-lex.europa.eu/eli/reg/2022/2554/oj

prevent the lack of availability, the impairment of the authenticity and integrity, the breaches of confidentiality and the loss of data;

Findings (1)

DORA-CH2-016 Deployment/ai-inference/vllm vLLM runs with --trust-remote-code: it executes code from the model repository

verdict	FAIL
container	vllm
path	/spec/template/spec/containers/0/args
source	test/corpus/baseline/toxic/input.yaml:1

WARN DORA–CH2–017 KS–AI–003 Model load may use pickle

severity fail | fix: workload patch (kshield remediate)

Supports evidence for

DORA Art. 9(3)(b)

DORA, CELEX 32022R2554, https://eur–lex.europa.eu/eli/reg/2022/2554/oj

minimise the risk of corruption or loss of data, unauthorised access and technical flaws that may hinder business activity;

DORA Art. 9(3)(c)

DORA, CELEX 32022R2554, https://eur–lex.europa.eu/eli/reg/2022/2554/oj

prevent the lack of availability, the impairment of the authenticity and integrity, the breaches of confidentiality and the loss of data;

Findings (1)

DORA–CH2–017 Deployment/ai–inference/vllm no ––load–format: vLLM falls back to .bin and .pt files when the model has no safetensors weights (set ––load–format safetensors)

verdict	WARN
container	vllm
path	/spec/template/spec/containers/0/args
source	test/corpus/baseline/toxic/input.yaml:1

FAIL DORA–CH2–018 KS–AI–004 Inference API exposed outside cluster (Service LoadBalancer/NodePort, Ingress) without auth

severity fail | fix: manual (kshield checks explain KS–AI–004)

Supports evidence for

DORA Art. 9(4)(b)

DORA, CELEX 32022R2554, https://eur–lex.europa.eu/eli/reg/2022/2554/oj

following a risk–based approach, establish a sound network and infrastructure management structure using appropriate techniques, methods and protocols that may include implementing automated mechanisms to isolate affected information assets in the event of cyber–attacks;

DORA Art. 9(4)(c)

DORA, CELEX 32022R2554, https://eur–lex.europa.eu/eli/reg/2022/2554/oj

implement policies that limit the physical or logical access to information assets and ICT assets to what is required for legitimate and approved functions and activities only, and establish to that end a set of policies, procedures and controls that address access rights and ensure a sound administration thereof;

Findings (1)

DORA–CH2–018 Service/ai–inference/vllm Service type NodePort exposes Deployment/ai–inference/vllm outside the cluster: vLLM container vllm has no ––api–key and no VLLM_API_KEY

verdict	FAIL
path	/spec/type
source	test/corpus/baseline/toxic/input.yaml:43

FAIL DORA–CH2–019 KS–AI–005 Ray GCS 6379, client 10001 or dashboard 8265 exposed beyond ClusterIP

severity fail | fix: workload patch (kshield remediate)

Supports evidence for

DORA Art. 9(4)(b)

DORA, CELEX 32022R2554, https://eur–lex.europa.eu/eli/reg/2022/2554/oj

following a risk–based approach, establish a sound network and infrastructure management structure using appropriate techniques, methods and protocols that may include implementing automated mechanisms to isolate affected information assets in the event of cyber–attacks;

DORA Art. 9(4)(c)

DORA, CELEX 32022R2554, https://eur–lex.europa.eu/eli/reg/2022/2554/oj

implement policies that limit the physical or logical access to information assets and ICT assets to what is required for legitimate and approved functions and activities only, and establish to that end a set of policies, procedures and controls that address access rights and ensure a sound administration thereof;

Findings (1)

DORA-CH2-019 RayCluster/ai-inference/rc head serviceType is NodePort: Ray GCS 6379, client 10001 and dashboard 8265 are reachable outside the cluster

verdict	**FAIL**
group	head
path	/spec/headGroupSpec/serviceType
source	test/corpus/baseline/toxic/input.yaml:107

FAIL DORA-CH2-020 KS-AI-006 Ray TLS off (RAY_USE_TLS not 1)

severity fail | fix: manual (kshield checks explain KS-AI-006)

Supports evidence for

DORA Art. 9(3)(a)

DORA, CELEX 32022R2554, https://eur-lex.europa.eu/eli/reg/2022/2554/oj

> ensure the security of the means of transfer of data;

Findings (3)

DORA-CH2-020 RayCluster/ai-inference/rc RAY_USE_TLS is not set: Ray traffic is not encrypted

verdict	**FAIL**
group	cpu
container	ray-worker
path	/spec/workerGroupSpecs/0/template/spec/containers/0/env
source	test/corpus/baseline/toxic/input.yaml:107

DORA-CH2-020 RayCluster/ai-inference/rc RAY_USE_TLS is not set: Ray traffic is not encrypted

verdict	**FAIL**
group	gpu
container	ray-worker
path	/spec/workerGroupSpecs/1/template/spec/containers/0/env
source	test/corpus/baseline/toxic/input.yaml:107

DORA-CH2-020 RayCluster/ai-inference/rc RAY_USE_TLS is not set: Ray traffic is not encrypted

verdict	**FAIL**
group	head
container	ray-head
path	/spec/headGroupSpec/template/spec/containers/0/env
source	test/corpus/baseline/toxic/input.yaml:107

FAIL DORA-CH2-022 KS-AI-008 Qdrant without API key or TLS

severity fail | fix: manual (kshield checks explain KS-AI-008)

Supports evidence for

DORA Art. 9(4)(c)

DORA, CELEX 32022R2554, https://eur-lex.europa.eu/eli/reg/2022/2554/oj

> implement policies that limit the physical or logical access to information assets and ICT assets to what is required for legitimate and approved functions and activities only, and establish to that end a set of policies, procedures and controls that address access rights and ensure a sound administration thereof;

DORA Art. 9(4)(d)

DORA, CELEX 32022R2554, https://eur-lex.europa.eu/eli/reg/2022/2554/oj

> implement policies and protocols for strong authentication mechanisms, based on relevant standards and dedicated control systems, and protection measures of cryptographic keys whereby data is encrypted based on results of approved data classification and ICT risk assessment processes;

DORA Art. 9(3)(a)

DORA, CELEX 32022R2554, https://eur-lex.europa.eu/eli/reg/2022/2554/oj

> ensure the security of the means of transfer of data;

Findings (2)

DORA-CH2-022 Deployment/ai-inference/qdrant Qdrant has no API key: QDRANT__SERVICE__API_KEY is not set and no mounted ConfigMap or Secret sets service.api_key

verdict	**FAIL**
container	qdrant
path	/spec/template/spec/containers/0/env
source	test/corpus/baseline/toxic/input.yaml:57

DORA–CH2–022 Deployment/ai–inference/qdrant Qdrant serves without TLS: QDRANT__SERVICE__ENABLE_TLS is not true and no mounted ConfigMap or Secret sets service.enable_tls: true

verdict	**FAIL**
container	qdrant
path	/spec/template/spec/containers/0/env
source	test/corpus/baseline/toxic/input.yaml:57

FAIL DORA–CH2–024 KS–NET–001 AI namespace has no default–deny egress (no CNP/NetworkPolicy in input or cluster)

severity fail | fix: guardrail policy (kshield remediate)

Supports evidence for

DORA Art. 9(4)(b)

DORA, CELEX 32022R2554, https://eur–lex.europa.eu/eli/reg/2022/2554/oj

> following a risk–based approach, establish a sound network and infrastructure management structure using appropriate techniques, methods and protocols that may include implementing automated mechanisms to isolate affected information assets in the event of cyber–attacks;

Findings (5)

DORA–CH2–024 Deployment/ai–inference/qdrant no NetworkPolicy or Cilium policy puts this workload under egress default–deny

verdict	**FAIL**
path	/metadata/namespace
source	test/corpus/baseline/toxic/input.yaml:57

DORA–CH2–024 Deployment/ai–inference/vllm no NetworkPolicy or Cilium policy puts this workload under egress default–deny

verdict	**FAIL**
path	/metadata/namespace
source	test/corpus/baseline/toxic/input.yaml:1

DORA–CH2–024 RayCluster/ai–inference/rc no NetworkPolicy or Cilium policy puts this workload under egress default–deny

verdict	**FAIL**
group	cpu
path	/metadata/namespace
source	test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–024 RayCluster/ai–inference/rc no NetworkPolicy or Cilium policy puts this workload under egress default–deny

verdict	**FAIL**
group	gpu
path	/metadata/namespace
source	test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–024 RayCluster/ai–inference/rc no NetworkPolicy or Cilium policy puts this workload under egress default–deny

verdict	**FAIL**
group	head
path	/metadata/namespace
source	test/corpus/baseline/toxic/input.yaml:107

FAIL DORA–CH2–027 KS–RT–001 No runtime shell–exec guard on AI namespace (Tetragon)

severity fail | fix: guardrail policy (kshield remediate)

Supports evidence for

DORA Art. 10(1)

DORA, CELEX 32022R2554, https://eur–lex.europa.eu/eli/reg/2022/2554/oj

> Financial entities shall have in place mechanisms to promptly detect anomalous activities, in accordance with Article 17, including ICT network performance issues and ICT–related incidents, and to identify potential material single points of failure.
>
> All detection mechanisms referred to in the first subparagraph shall be regularly tested in accordance with Article 25.

Findings (5)

DORA–CH2–027 Deployment/ai–inference/qdrant no Tetragon shell–exec guard covers this workload
verdict FAIL
path /metadata/namespace
source test/corpus/baseline/toxic/input.yaml:57

DORA–CH2–027 Deployment/ai–inference/vllm no Tetragon shell–exec guard covers this workload
verdict FAIL
path /metadata/namespace
source test/corpus/baseline/toxic/input.yaml:1

DORA–CH2–027 RayCluster/ai–inference/rc no Tetragon shell–exec guard covers this workload
verdict FAIL
group cpu
path /metadata/namespace
source test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–027 RayCluster/ai–inference/rc no Tetragon shell–exec guard covers this workload
verdict FAIL
group gpu
path /metadata/namespace
source test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–027 RayCluster/ai–inference/rc no Tetragon shell–exec guard covers this workload
verdict FAIL
group head
path /metadata/namespace
source test/corpus/baseline/toxic/input.yaml:107

FAIL DORA–CH2–028 KS–RT–002 No runtime egress–connect guard on AI namespace (Tetragon)

severity fail | fix: guardrail policy (kshield remediate)

Supports evidence for

DORA Art. 10(1)

DORA, CELEX 32022R2554, https://eur–lex.europa.eu/eli/reg/2022/2554/oj

> Financial entities shall have in place mechanisms to promptly detect anomalous activities, in accordance with Article 17, including ICT network performance issues and ICT–related incidents, and to identify potential material single points of failure.
>
> All detection mechanisms referred to in the first subparagraph shall be regularly tested in accordance with Article 25.

Findings (5)

DORA–CH2–028 Deployment/ai–inference/qdrant no Tetragon egress–connect guard covers this workload
verdict FAIL
path /metadata/namespace
source test/corpus/baseline/toxic/input.yaml:57

DORA–CH2–028 Deployment/ai–inference/vllm no Tetragon egress–connect guard covers this workload
verdict FAIL
path /metadata/namespace
source test/corpus/baseline/toxic/input.yaml:1

DORA–CH2–028 RayCluster/ai–inference/rc no Tetragon egress–connect guard covers this workload
verdict FAIL
group cpu
path /metadata/namespace
source test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–028 RayCluster/ai–inference/rc no Tetragon egress–connect guard covers this workload
verdict FAIL
group gpu
path /metadata/namespace
source test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–028 RayCluster/ai–inference/rc no Tetragon egress–connect guard covers this workload

verdict	**FAIL**
group	head
path	/metadata/namespace
source	test/corpus/baseline/toxic/input.yaml:107

FAIL DORA–CH2–029 KS–RT–003 No admission guard for root, host namespaces, shm hostPath, pickle load (Kyverno)

severity fail | fix: guardrail policy (kshield remediate)

Supports evidence for

DORA Art. 9(4)(c)

DORA, CELEX 32022R2554, https://eur–lex.europa.eu/eli/reg/2022/2554/oj

> implement policies that limit the physical or logical access to information assets and ICT assets to what is required for legitimate and approved functions and activities only, and establish to that end a set of policies, procedures and controls that address access rights and ensure a sound administration thereof;

RTS 2024/1774 Art. 11(2)(b)

RTS 2024/1774, CELEX 32024R1774, https://eur–lex.europa.eu/eli/reg_del/2024/1774/oj

> the identification of a secure configuration baseline for ICT assets that minimise exposure of those ICT assets to cyber threats and measures to verify regularly that those baselines are effectively deployed;

Findings (5)

DORA–CH2–029 Deployment/ai–inference/qdrant no kshield admission guard (Kyverno) covers this namespace

verdict	**FAIL**
path	/metadata/namespace
source	test/corpus/baseline/toxic/input.yaml:57

DORA–CH2–029 Deployment/ai–inference/vllm no kshield admission guard (Kyverno) covers this namespace

verdict	**FAIL**
path	/metadata/namespace
source	test/corpus/baseline/toxic/input.yaml:1

DORA–CH2–029 RayCluster/ai–inference/rc no kshield admission guard (Kyverno) covers this namespace

verdict	**FAIL**
group	cpu
path	/metadata/namespace
source	test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–029 RayCluster/ai–inference/rc no kshield admission guard (Kyverno) covers this namespace

verdict	**FAIL**
group	gpu
path	/metadata/namespace
source	test/corpus/baseline/toxic/input.yaml:107

DORA–CH2–029 RayCluster/ai–inference/rc no kshield admission guard (Kyverno) covers this namespace

verdict	**FAIL**
group	head
path	/metadata/namespace
source	test/corpus/baseline/toxic/input.yaml:107

Errors

No errors.